

TP5 : Kerberos

Sécurité des Réseaux, Filière ISC – Année 2 - 2021/2022

Nikola Antonijevic et Ludovico Grabau

11.01.2022

TP5 : Kerberos

De quoi s'agit-il

Démarche, résultats et réponses

1. Préparation des machines
2. Installation des paquets Kerberos et configuration
3. Initialisation de la base de données, création du premier principal
4. Récupération d'un ticket sur une autre machine
5. Création du principal pour le service ssh et installation de la clé de service
6. Configuration du serveur et client ssh

Conclusion

De quoi s'agit-il

Dans ce TP, nous faisons la configuration d'un serveur *kerberos*, un client et un serveur *ssh* à kerberiser, dans un environnement virtuel dédié à Kerberos.

Démarche, résultats et réponses

1. Préparation des machines

a) Adresses :

Machine	enp0s9 (Internal)	enp0s3 (NAT)
Serveur Kerberos	192.168.0.2/24	10.0.2.15
Client	192.168.0.3/24	10.0.2.15
Serveur SSH à Kerberiser	192.168.0.1/24	10.0.2.15

Commandes :

- hostname -> System hostname (nom de l'ordinateur)
- hostname -d -> Domain system (nom du DNS)
- hostname -f -> FQDN (Nom de l'ordinateur avec le FQDN entier)

b) Horloges :

Commande pour synchroniser les horloges : ntpdate pool.ntp.org

c) DNS

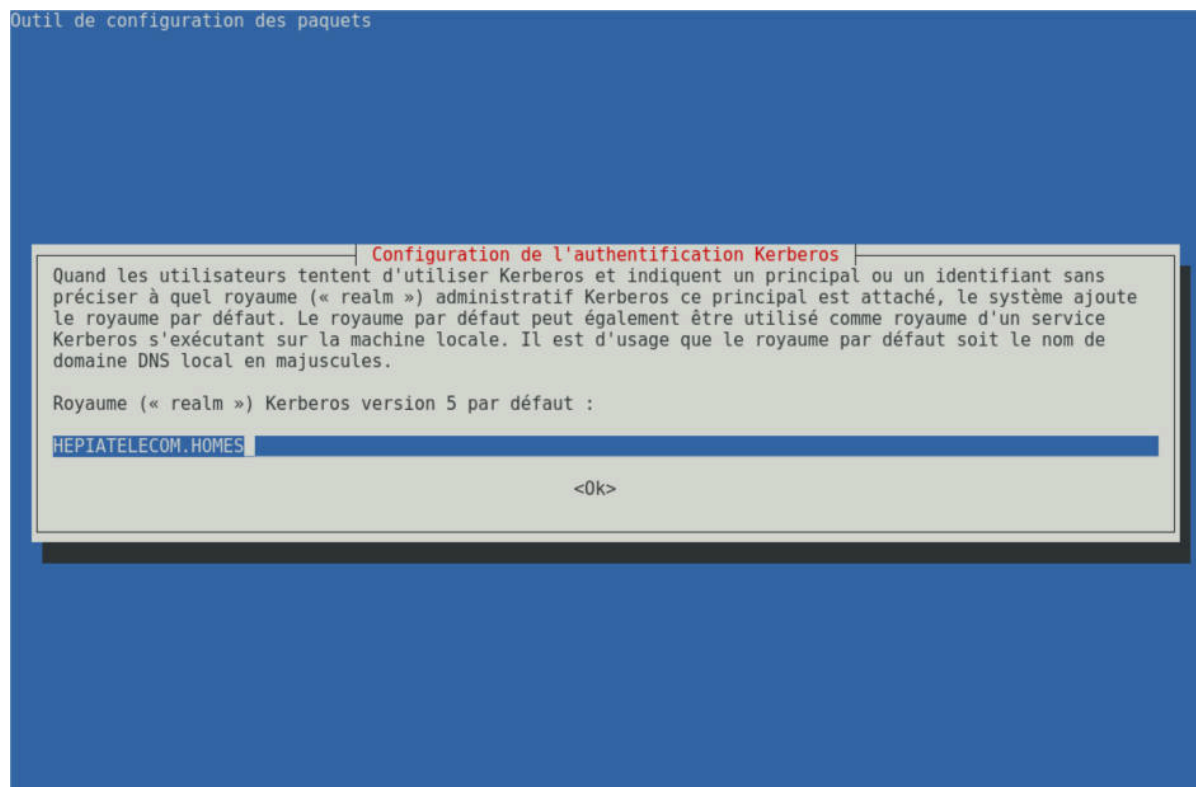
Commande pour la résolution des noms DNS : nameserver 192.168.0.1

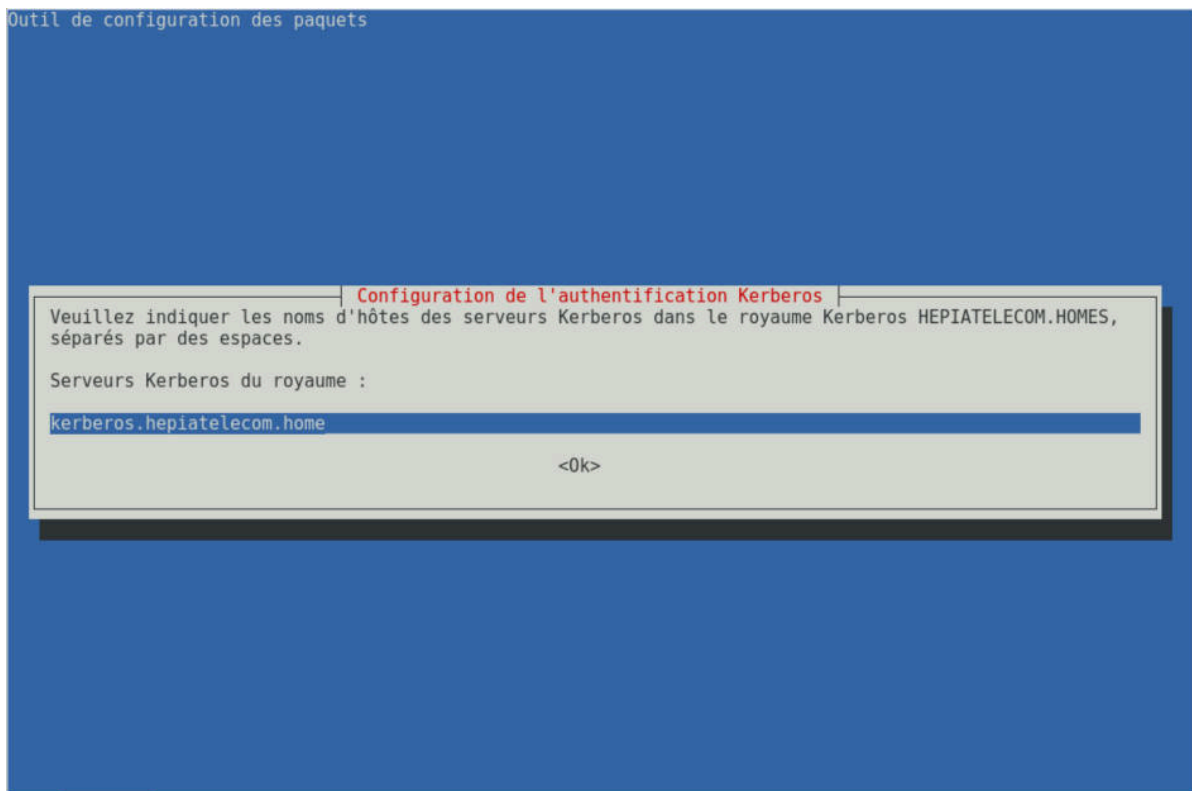
2. Installation des paquets Kerberos et configuration

Serveur Kerberos : kerberos.hepiatelecom.home

```
> sudo su
> apt-get install heimdal-servers
> apt-get install heimdal-clients
> apt-get install heimdal-kdc
> apt-get install krb5-config
```

Outil de configuration des paquets





3. Initialisation de la base de données, création du premier principal

(s'assurer d'éteindre enp0s3)

Créer une clef de stockage sur le serveur Kerberos pour chiffrer la base de données.

```
root@kerberos:/home/student# kstash --random-key
kstash: writing key to `/var/lib/heimdal-kdc/m-key'
```

Ensuite créer la base de données à l'aide de l'utilitaire d'administration de Kerberos.

```
> kadmin -l
> init HEPIATELECOM.HOME
```

Créer un user sur Kerberos.

```
> add Ludovico
```

Vérification que les étapes se sont déroulées correctement et que le user existe bien.

```
> get Ludovico
```

```

root@kerberos:/home/student# kadmin -l
kadmin> init HEPIATELECOM.HOME
Realm max ticket life [unlimited]:
Realm max renewable ticket life [unlimited]:
kadmin> add Ludovico
Max ticket life [1 day]:
Max renewable life [1 week]:
Principal expiration time [never]:
Password expiration time [never]:
Attributes []:
Policy [default]:
Ludovico@HEPIATELECOM.HOMES's Password:
Verify password - Ludovico@HEPIATELECOM.HOMES's Password:
kadmin> get Ludovico
Principal: Ludovico@HEPIATELECOM.HOMES
Principal expires: never
Password expires: never
Last password change: 2022-01-11 14:48:44 UTC
Max ticket life: 1 day
Max renewable life: 1 week
Kvno: 1
Mkvno: unknown
Last successful login: never
Last failed login: never
Failed login count: 0
Last modified: 2022-01-11 14:48:44 UTC
Modifier: kadmin/admin@HEPIATELECOM.HOMES
Attributes:
Keytypes: aes256-cts-hmac-sha1-96(pw-salt)[1], des3-cbc-sha1(pw-salt)[1], arcfour-hmac-md5(pw-salt)
[1]
PK-INIT ACL:
Aliases:

```

Redémarrer le serveur de clefs pour créer le ticket.

```
> service heimdal-kdc restart
```

4. Récupération d'un ticket sur une autre machine

```
> useradd -m ludovico
```

(s'assurer d'éteindre enp0s3)

MIT Kerberos Documentation : https://web.mit.edu/kerberos/krb5-1.12/doc/user/user_commands/kinit.html

Nous avons lancé l'utilitaire "kinit" depuis l'invité de commande qui obtient et met en cache un "Ticket Granting Ticket" pour *principal*.

Ensuite on a utilisé la commande "klist" pour lister les tickets Kerberos contenus soit dans le cache soit dans un fichier *keytab*, comme on peut le voir dans l'image en dessous.

```

ludovico@client:~$ su ludovico
Mot de passe :
$ kinit
ludovico@HEPIATELECOM.HOMES's Password:
$ klist
Credentials cache: FILE:/tmp/krb5cc_1001
Principal: ludovico@HEPIATELECOM.HOMES

    Issued                Expires               Principal
Jan 11 17:04:24 2022  Jan 12 17:04:24 2022  krbtgt/HEPIATELECOM.HOMES@HEPIATELECOM.HOMES
$ █

```

On a dû modifier *HEPIATELECOM.HOME* en *HEPIATELECOM.HOMES* car dans la configuration, lors du téléchargement des paquets, on a eu par défaut *HEPIATELECOM.HOMES* qui nous a été proposé comme Royaume et nous l'avons mis en place de cette façon.

5. Création du principal pour le service ssh et installation de la clé de service

(s'assurer d'éteindre enp0s3)

Pour pouvoir faire du "kadmin" hors de kerberos il faut modifier l'ACL (Access Control List).

```
> nano /etc/heimdal-kdc/kadmin.acl
(Modifier le fichier en lui rajoutant la ligne suivante :
ludovico@HEPIATELECOM.HOMES all,get-keys)
> service heimdal-kdc restart (redémarrer le serveur de clefs pour mettre à jour
le ACL)
```

Nous allons maintenant créer un *principal* pour un service et l'exporter.

```
> kadmin -p ludovico
> add --random-key --use defaults host/server.hepiatelecom.home
> ext_keytab host/server.hepiatelecom.home
> ktutil list
```

```
root@kerberos:/home/ludovico# ktutil list
FILE:/etc/krb5.keytab:

Vno  Type                                Principal
-----
1    aes256-cts-hmac-sha1-96            host/server.hepiatelecom.home@HEPIATELECOM.HOMES
1    des3-cbc-sha1                      host/server.hepiatelecom.home@HEPIATELECOM.HOMES
1    arcfour-hmac-md5                   host/server.hepiatelecom.home@HEPIATELECOM.HOMES
```

6. Configuration du serveur et client ssh

(s'assurer de bien avoir reallumé enp0s3)

Installer et configurer le serveur ssh de sorte à ce qu'il utilise Kerberos.

```
> nano /etc/ssh/sshd_config

KerberosAuthentication yes
KerberosTicketCleanup yes
GSSAPIAuthentication yes
GSSAPICleanupCredentials yes
```

A quoi sert KerberosTicketCleanup ?

C'est une option qui indique s'il faut supprimer/détruire automatiquement le fichier cache des tickets de l'utilisateur au moment de la déconnexion ou non.

On crée l'utilisateur sur le serveur ssh.

```
> useradd ludovico
```

(s'assurer d'éteindre enp0s3)

On se connecte au serveur.

```
> ssh 192.168.0.1
> klist
```

```
$ klist
Credentials cache: FILE:/tmp/krb5cc_1001
Principal: ludovico@HEPIATELECOM.HOMES

    Issued                Expires               Principal
Jan 11 17:04:24 2022  Jan 12 17:04:24 2022  krbtgt/HEPIATELECOM.HOMES@HEPIATELEC
OM.HOMES
$ ssh 192.168.0.1
The authenticity of host '192.168.0.1 (192.168.0.1)' can't be established.
ECDSA key fingerprint is SHA256:lxSpf4QncD39/W6+r+PuQoBYxXcPH6qwz3S0Ly9KSM4.
Are you sure you want to continue connecting (yes/no)? yes
Warning: Permanently added '192.168.0.1' (ECDSA) to the list of known hosts.
ludovico@192.168.0.1's password:
Linux kerberos 4.9.0-6-amd64 #1 SMP Debian 4.9.88-1+deb9u1 (2018-05-07) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
$ klist
klist: No ticket file: /tmp/krb5cc_1001
```

On remarque sur l'image au-dessus que le fichier contenant les tickets n'existe plus.

Conclusion

En conclusion, nous avons accomplis les étapes suivantes, mettre en place et configurer les trois machines pour pouvoir employer Kerberos pour sécuriser notre serveur ssh, pour cela nous avons installé plusieurs paquets pour Kerberos, ensuite nous avons établie la base de donnée à protéger et par conséquent créé le premier *principal*, correctement mis en place cette base et généré un ticket. Ce ticket nous l'avons ensuite récupéré sur une autre machine, puis nous sommes passé au serveur ssh où il nous a fallu créer un *principal* pour un service à exporter et enfin terminer la configuration du serveur et client ssh pour pouvoir s'y connecter.